CS-01 TP · BTS SIO 2E ANNÉE · CYBERSÉCURITÉ

Analyse d'un incident dans une PME

Hameçonnage, macro malveillante et compromission du domaine : actifs, vulnérabilités, chaîne d'attaque et mesures.

AUTEUR
Constant Segrétain

CONTEXTE
étude de cas en cours

DATE
mars 2026

Le contexte

Entreprise de 70 salariés sur deux sites. Active Directory sous Windows Server, serveur de fichiers, sauvegarde sur un NAS local non isolé, VPN accessible depuis Internet, RDP ouvert sur le pare-feu vers un serveur interne, mots de passe de 8 caractères sans complexité, pas de MFA, journaux non centralisés.

L'incident : un salarié des RH reçoit un faux courriel d'un partenaire juridique et ouvre la pièce jointe, un « avenant » contenant une macro. Dans les heures qui suivent : connexion VPN depuis une adresse IP étrangère, tentatives d'authentification répétées sur le contrôleur de domaine, création d'un nouveau compte utilisateur.

1. Actifs critiques

Actif	Pourquoi il est critique
Contrôleur de domaine (AD)	Contrôle tous les comptes et tous les postes.
Comptes administrateurs du domaine	Leur compromission donne le contrôle total du SI.
Serveur de fichiers partagé	Données de l'entreprise, cible du chiffrement par rançongiciel.
NAS de sauvegarde	Seul moyen de restaurer ; non isolé, il peut être chiffré avec le reste.
Passerelle VPN	Porte d'entrée depuis Internet.
Serveur exposé en RDP	Autre porte d'entrée, souvent visée par des attaques par mot de passe.
Poste et compte de l'utilisateur RH	Point d'entrée de l'attaque.
Données RH	Données personnelles des salariés : obligation de protection (RGPD) et de notification en cas de fuite.

2. Vulnérabilités

- Pas de MFA, ni sur le VPN ni sur le RDP.
- Mots de passe courts et sans complexité.
- RDP ouvert directement sur Internet.
- Sauvegarde non isolée du réseau de production.
- Journaux non centralisés : l'attaque est détectée tard, et difficile à reconstituer.
- Pas de filtrage des pièces jointes ni de blocage des macros venant d'Internet.

3. Chaîne d'attaque plausible

1. **Reconnaissance** : l'attaquant identifie un partenaire juridique et un salarié RH.
2. **Accès initial** : courriel piégé, la macro s'exécute sur le poste RH.
3. **Vol d'identifiants** : les identifiants de l'utilisateur sont récupérés sur le poste.
4. **Persistance** : connexion VPN depuis l'étranger avec ces identifiants, possible faute de MFA.
5. **Élévation de privilèges** : tentatives répétées sur le contrôleur de domaine, facilitées par des mots de passe faibles.
6. **Maintien de l'accès** : création d'un compte pour revenir même si le mot de passe RH est changé.
7. **Mouvement latéral** vers le serveur de fichiers et le NAS.
8. **Action finale** : exfiltration des données RH, puis chiffrement des fichiers et des sauvegardes.

4. Mesures immédiates

- Isoler le poste RH du réseau, sans l'éteindre, pour conserver les traces.
- Désactiver le compte créé par l'attaquant et couper les sessions VPN en cours.
- Réinitialiser les mots de passe du compte RH et des comptes à privilèges.
- Déconnecter le NAS pour protéger les sauvegardes.
- Collecter les journaux disponibles (VPN, contrôleur de domaine, messagerie) et prévenir la direction ; si des données personnelles ont fuité, notifier la CNIL sous 72 heures.

5. Mesures préventives

- MFA sur le VPN, et fermeture du RDP exposé : accès aux serveurs par le VPN seulement.
- Mots de passe de 12 caractères minimum avec complexité, verrouillage après plusieurs échecs.
- Sauvegarde isolée et hors ligne (règle 3-2-1), avec tests de restauration.
- Centralisation des journaux et alerte sur les créations de comptes et les connexions VPN anormales.
- Blocage des macros venant d'Internet par GPO et filtrage des pièces jointes.
- Comptes d'administration séparés des comptes de travail quotidiens, et sensibilisation des salariés à l'hameçonnage.